TOPS TECH Task-9 (CS)

Task-9 Vulnerability Scanning Submitted

1. **Install and run the free version of the OpenVAS or Nessus vulnerability scanner on your system, and perform a basic scan of your own computer or a local virtual machine.**

   Ans:

   Vulnerability Scanning Using Nessus Essentials

   Objective:
   - To identify security vulnerabilities, misconfigurations, and potential risks present on the local system using Nessus Essentials Vulnerability Scanner.

   - Open Nessus through the web interface using:
     https://localhost:8834

   - Create a new scan by selecting "Basic Network Scan".

   Enter the scan details:
   - Name: Localhost Scan
   - Target: 127.0.0.1
   - Save the scan configuration and launch the scan.
   - Wait for the scan to complete and review the generated report.

   Observations:
   - Nessus successfully scanned the local system and identified active services and system configurations.
   - The scanner checked installed software, operating system configuration, open ports, and security settings.
   - Several informational items and warnings were detected during the scan.
   - Nessus generated a detailed report showing vulnerabilities categorized by severity levels such as Critical, High, Medium, Low, and Informational.

- The scan report also provided recommendations for improving system security.

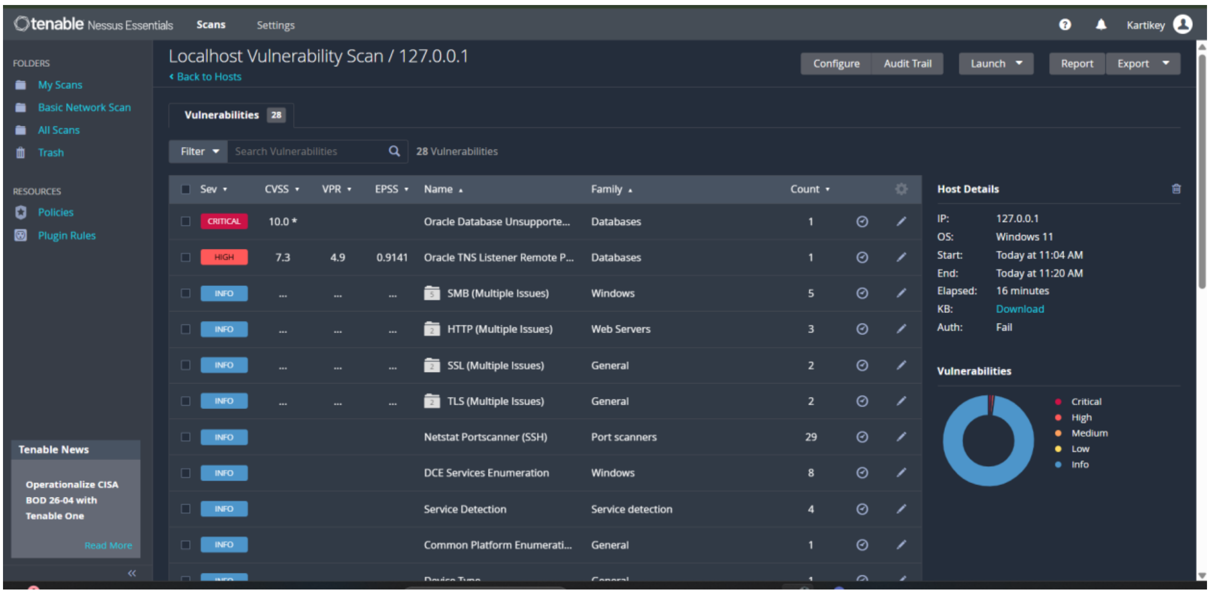
Sample Vulnerabilities Identified:

- Severity Description
- Medium Outdated software version detected
- Low SSL/TLS configuration warning
- Info Open network service identified

⇨ Nessus Essentials was successfully installed and configured.

⇨ A vulnerability assessment of the local system was performed successfully.

⇨ The scan report identified system information, open services, and potential security risks that can be used to improve the overall security posture of the system.



TOPS TECH Task-9 (CS)

2. **Scan your Wi-Fi router's IP address using Nmap and list all open ports detected.

Hint: Use the command 'nmap -v [router_ip]' in your terminal or command prompt.**

Ans:

Wi-Fi Router Port Scanning Using Nmap

Objective:
- To identify open ports and associated network services running on the Wi-Fi router using the Nmap network scanning tool.

Command:
- → ipconfig
- ➢ The ipconfig command is used to identify the Default Gateway address, which represents the IP address of the Wi-Fi router.

Example:
- Default Gateway : 192.168.31.1

Command:
- nmap -sV 192.168.31.1

- ➢ The nmap -sV command scans the target device and attempts to determine the services and versions running on open ports.

Observations:
- Nmap successfully scanned the Wi-Fi router and identified several open ports.
- The detected ports were associated with router management and network communication services.
- Open ports indicate services currently accepting network connections.

The following open ports were identified:

Port Number	**Protocol**	**State**	**Service**
53	TCP	OPEN	domain
80	TCP	OPEN	http
443	TCP	OPEN	https
8080	TCP	OPEN	http-proxy
8443	TCP	OPEN	https-alt

Port Description:

Port Number	**Description**
53	Domain Name Service (DNS)
80	Web-based Router Management Interface
443	Secure Router Management Interface
8080	Alternative HTTP Management Service
8443	Alternative Secure HTTPS Management Service

- The router was found to be running network management services required for administration and internet connectivity.
- Ports 8080 and 8443 indicate additional web-based management interfaces available on the router.
- No critical issues were observed during the basic port scan.

  - ⇨ The Wi-Fi router was successfully scanned using Nmap.
  - ⇨ Open ports and associated services were identified and documented.
  - ⇨ The scan provided useful information regarding the network services exposed by the router and helped understand the network attack surface.

3. **Analyze the scan report from your vulnerability scanner and identify at least 3 vulnerabilities or warnings it reports; for each, write a one-line description of what the risk is.**
   Ans:

   Vulnerability Analysis Using Nessus Scan Report

   Objective:
   - To analyze the Nessus vulnerability scan report and identify vulnerabilities and security warnings present on the local system.

   Tool Used:
   - Nessus Essentials Vulnerability Scanner

   Target:
   - 127.0.0.1 (Localhost)

   Observations:
   - Nessus successfully scanned the local system and identified 28 vulnerabilities and informational findings.
   - The scan report categorized findings into Critical, High, and Informational severity levels.
   - Several issues related to Oracle services, SMB services, HTTP services, SSL/TLS configurations, and service enumeration were detected.

   The following vulnerabilities/warnings were identified:

   1. Oracle Database Unsupported Version
      - Severity: Critical
      - Risk:
      - ➔ The Oracle Database version installed on the system is no longer supported by the vendor.
      - ➔ Unsupported software does not receive security updates and may contain known vulnerabilities that attackers can exploit.

Recommendation:

- Upgrade to a supported Oracle Database version and apply the latest security patches.

2. Oracle TNS Listener Remote Information Disclosure

- Severity: High
- Risk:

➔ The Oracle TNS Listener may disclose sensitive information about the database environment, which can assist attackers in gathering intelligence for further attacks.

Recommendation:

- Restrict listener access and apply Oracle security updates.

3. SMB (Multiple Issues)

- Severity: Informational
- Risk:

➔ SMB services may expose information about the system configuration and network resources, increasing the attack surface if improperly

Recommendation:

- Disable unnecessary SMB services and restrict access using firewall rules.

4. HTTP (Multiple Issues)

- Severity: Informational
- Risk:

➔ Web services may reveal server information, configuration details, or application fingerprints that can aid attackers during reconnaissance.

Recommendation:

- Minimize information disclosure and keep web services updated.

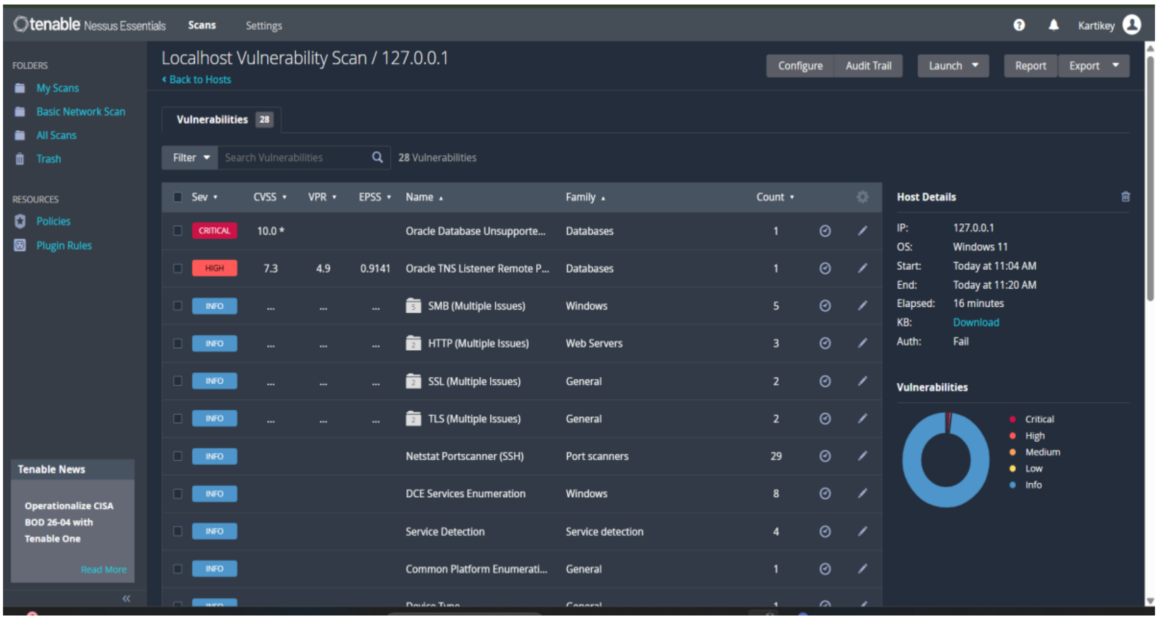
4. SSL/TLS (Multiple Issues)
   - Severity: Informational
   - Risk:
   - ➔ Weak SSL/TLS configurations may expose encrypted communications to interception or downgrade attacks.

Recommendation:
   - Use strong encryption protocols and disable outdated SSL/TLS versions.

Summary Table:

Vulnerability Severity Risk Description
- Oracle Database Unsupported Version Critical Unsupported software may contain exploitable vulnerabilities.
- Oracle TNS Listener Information Disclosure High Sensitive system information may be exposed.
- SMB Multiple Issues Informational May reveal system and network details.
- HTTP Multiple Issues Informational May expose web server information.
- SSL/TLS Multiple Issues Informational Weak encryption settings may affect communication security.

⇨ The Nessus scan report was successfully analyzed.
⇨ One Critical vulnerability, one High severity vulnerability, and multiple informational security warnings were identified.
⇨ Appropriate recommendations were suggested to reduce security risks and improve the overall security posture of the system.



4. **Pick any app you use daily (like Instagram, Zomato, or Paytm) and research one real vulnerability that was found in it in the past; write a short summary of what the vulnerability was and how it could have been detected by scanning tools.**

<u>Ans:</u>

<u>Research on a Real Vulnerability in WhatsApp</u>

<u>Objective:</u>

- To study a real-world security vulnerability discovered in a widely used application and understand its impact and detection methods.

<u>Application Selected:</u>

- WhatsApp

<u>Vulnerability Name:</u>

- Pegasus Spyware Vulnerability (2019)

- In 2019, a serious vulnerability was discovered in WhatsApp that allowed attackers to install Pegasus spyware on a victim's mobile device.
- The vulnerability existed in WhatsApp's voice calling feature.
- An attacker could exploit this flaw by placing a specially crafted WhatsApp call to the target device.
- In some cases, the spyware could be installed even if the victim did not answer the call.

Impact:

- Attackers could gain unauthorized access to sensitive information stored on the device.
- Personal messages, emails, contacts, location data, and other private information could potentially be monitored.
- The vulnerability affected both Android and iOS devices.

Risk Analysis:

Risk Type Description:

- Privacy Risk User data could be accessed without permission.
- Information Disclosure Sensitive information could be exposed.
- Remote Exploitation Attackers could compromise a device remotely.
- Surveillance Risk Spyware could monitor user activities secretly.

How Scanning Tools Could Detect It:

- Vulnerability scanners can identify outdated application versions that contain known security flaws.
- Security assessment tools can compare installed software versions against vulnerability databases.
- Mobile security scanners can detect suspicious application behaviour and unusual network activity.
- Regular security audits and vulnerability assessments help identify software that requires security updates.

Control:

- Update WhatsApp to the latest version.
- Install security patches released by the vendor.
- Avoid using outdated software versions.
- Enable device security features and keep the operating system updated.

⇨ A real-world vulnerability affecting WhatsApp was successfully studied.
⇨ The Pegasus spyware vulnerability demonstrated how a software flaw can lead to serious privacy and security risks.
⇨ Regular updates, vulnerability scanning, and security monitoring can help prevent such attacks and improve overall cybersecurity.

**5. Use ChatGPT or Copilot to generate a basic bash or PowerShell script that runs Nmap on a list of 3 IP addresses and saves the results to separate files; copy and run the script, and share the output files.

Hint: Ask the AI tool for a script that loops through IPs and uses Nmap for each.**

Ans:

Automated Nmap Scanning Using PowerShell Script

Objective:

- To automate Nmap scanning of multiple IP addresses using a PowerShell script and store the results in separate output files.

Tool Used:

- Nmap
- Windows PowerShell

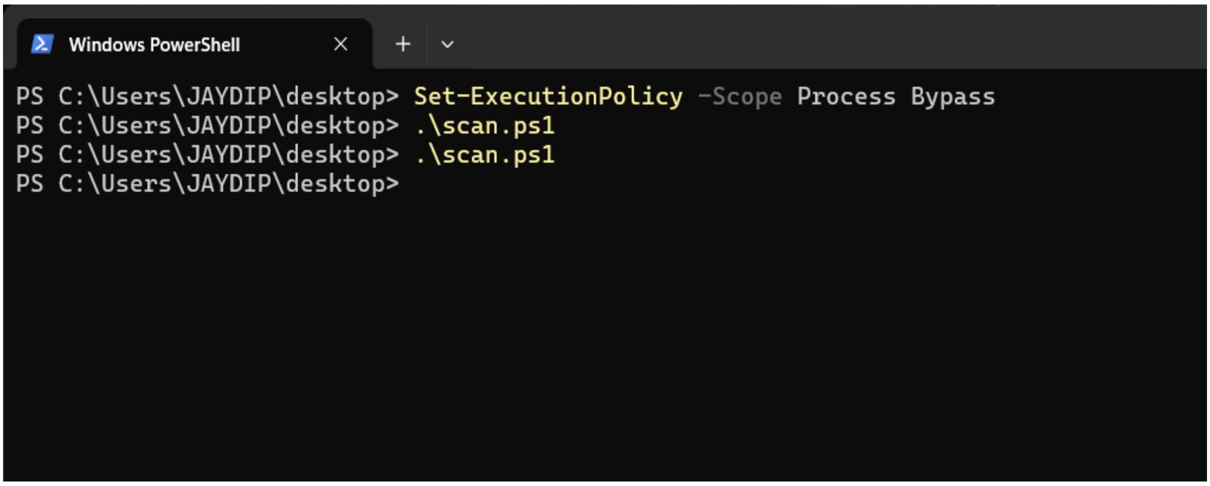
PowerShell Script:

```
$ips = @(
"192.168.31.1",
"127.0.0.1",
"192.168.31.165"
)

foreach ($ip in $ips)
{
nmap -F $ip > "$ip.txt"
}
```

Script Explanation:

- The script stores three IP addresses in an array.
- The foreach loop processes each IP address one by one.
- Nmap performs a fast scan (-F) on each target.
- The output of each scan is redirected to a separate text file.
- The generated files are named according to the scanned IP address.



Observations:

- The script successfully automated the scanning process.
- Each target was scanned individually.
- Scan results were stored in separate files for easier analysis.
- The generated reports contained information about open ports and available network services.

⇨ A PowerShell script was successfully generated using ChatGPT.
⇨ Nmap scans were executed automatically on multiple IP addresses.
⇨ Individual scan reports were generated and stored in separate output files, demonstrating basic automation of network scanning tasks.